HTTP Strict Transport Security (HSTS)

HTTP Strict Transport Security (HSTS) is a mechanism for websites to instruct web browsers that the site should only be accessed over HTTPS. This mechanism works by sites sending a `Strict-Transport-Security` HTTP response header containing the site's policy.

HSTS is supported by most major browsers. For more details on HSTS, see RFC 6797.

Benefits of HSTS

When a web browser enforces a domain's HSTS policy, it will upgrade all `http://` URLs for that domain to HTTPS. If the policy also sets `includeSubDomains`, it will do this for all subdomains as well.

A site that enables HSTS helps protect its users from the following attacks done by an on-path attacker:

- **Browsing history leaks**: If a user clicks on an HTTP link to a site, an on-path network observer can see that URL. If the site has an HSTS policy that is enforced, the browser upgrades that URL to HTTPS and the path is not visible to the network observer.
- **Protocol downgrades**: If a site redirects from HTTP to HTTPS, an on-path network attacker can intercept and re-write the redirect to keep the browser using plaintext HTTP.
- **Cookie hijacking**: On HTTP requests, an on-path network attacker can see and modify cookies. Even if the site redirects to HTTPS, the on-path attacker can inject cookies into the redirect response.

Deployment Recommendations

If your site is committed to HTTPS and you want browsers to enforce that your page is loaded only over HTTPS, we suggest the following steps to enable HSTS:

1. Examine all subdomains (and nested subdomains) of your site and make sure that they work properly over HTTPS.
    - **Note:** This also includes internal subdomains that are not publicly accessible.

2. Add the `Strict-Transport-Security` header to all HTTPS responses and ramp up the `max-age` in stages, using the following header values:
   - 5 minutes:

     `max-age=300; includeSubDomains`
   - 1 week:

     `max-age=604800; includeSubDomains`
   - 1 month:

     `max-age=2592000; includeSubDomains`

   During each stage, check for broken pages and monitor your site's metrics (e.g. traffic, revenue). Fix any problems that come up and then wait the full `max-age` of the stage before you move on. For example, wait a month in the last stage.

If you have a group of employees or users who can beta test the deployment, consider trying the first few ramp-up stages on those users. Then make sure to go through all stages for all users, starting over from the beginning.

Consult the Mozilla Web Security guidelines and the Google Web Fundamentals pages on security for more concrete advice about HTTPS deployment.

Preloading HSTS

Since sites tell the browser that they support HSTS when the browser visits, the browser cannot know a site's HSTS policy before the user has visited the site for the first time. As a result, the browser can not require HTTPS until after the first time it has connected to the site, possibly leaving the user unprotected. After this first load, the web browser has the site's HSTS policy and is able to require HTTPS for all subsequent loads.

To account for this first-load problem, Chrome maintains a list of domains that have a strong HSTS policy and are HTTPS only. This HSTS preload list is built into Chrome. Requests to these domains will only be made over HTTPS; any HTTP requests will be upgraded to HTTPS and fail to connect if HTTPS is unavailable. Other major browsers (Firefox, Safari, IE 11 and Edge) also have HSTS preload lists based on the Chrome list.

Many browsers (Chrome, Safari) will automatically upgrade all HTTP navigations to HTTPS, regardless of the domain's HSTS policy. HSTS preloading only provides value when these upgrades fail in the presence of an active attacker. The benefits

provided by HSTS preloading are minimal compared to the benefits provided by HSTS. While HSTS is recommended, **HSTS *preloading* is not recommended**.

Submission Requirements

If a site sends the `preload` directive in an HSTS header, it is considered to be requesting inclusion in the preload list and may be submitted via the form on this site.

In order to be accepted to the HSTS preload list through this form, your site must satisfy the following set of requirements:

1. Serve a valid **certificate**.
2. **Redirect** from HTTP to HTTPS on the same host, if you are listening on port 80.
3. Serve all **subdomains** over HTTPS.
    - In particular, you must support HTTPS for the `www` subdomain if a DNS record for that subdomain exists.
    - **Note:** HSTS preloading applies to *all* subdomains, including internal subdomains that are not publicly accessible.
4. Serve an **HSTS header** on the base domain for HTTPS requests:
    - The `max-age` must be at least `31536000` seconds (1 year).
    - The `includeSubDomains` directive must be specified.
    - The `preload` directive must be specified.
    - If you are serving an additional redirect from your HTTPS site, that redirect must still have the HSTS header (rather than the page it redirects to).

For more details on HSTS, please see RFC 6797. Here is an example of a valid HSTS header:

```
Strict-Transport-Security:
max-age=63072000; includeSubDomains; preload
```

You can check the status of your request by entering the domain name again in the form above, or consult the current Chrome preload list by visiting `chrome://net-internals/#hsts` in your browser. Note that new entries are hardcoded into the Chrome source code and can take several months before they reach the stable version.

Continued Requirements

You must make sure your site continues to satisfy the submission requirements at all times. Note that removing the `preload` directive from your header will make

your site immediately eligible for the removal form, and that sites may be removed automatically in the future for failing to keep up the requirements.

In particular, the requirements above apply to all domains submitted through `hstspreload.org` on or after **October 11, 2017** (i.e. preloaded after Chrome 63)

The same requirements apply to earlier domains submitted on or after **February 29, 2016** (i.e. preloaded after Chrome 50), except that the required max-age for those domains is only `10886400` seconds.

Preloading Should Be Opt-In

If you maintain a project that provides HTTPS configuration advice or provides an option to enable HSTS, **do not include the `preload` directive by default**. We get regular emails from site operators who tried out HSTS this way, only to find themselves on the preload list without realizing that some subdomains cannot support HTTPS. Removal tends to be slow and painful for those sites.

Projects that support or advise about HSTS and HSTS preloading should ensure that site operators understand the long-term consequences of preloading before they turn it on for a given domain. They should also be informed that they need to meet additional requirements and submit their site to hstspreload.org to ensure that it is successfully preloaded (i.e. to get the full protection of the intended configuration).

Submission Form

If you still wish to submit your domain for inclusion in Chrome's HSTS preload list and you have followed our deployment recommendations of slowly ramping up the `max-age` of your site's `Strict-Transport-Security` header, you can use this form to do so:

Domain to preload: forensiq.pt

Check HSTS preload status and eligibility

Status: forensiq.pt is not preloaded.
Eligibility: forensiq.pt is eligible for the HSTS preload list.

Submit

- [x] I understand that preloading `forensiq.pt` through this form will prevent **all subdomains and nested subdomains** from being accessed without a valid HTTPS certificate:

  ```
  *.forensiq.pt
  *.*.forensiq.pt
  ...
  ```

Submit forensiq.pt to the HSTS preload list

Success

`forensiq.pt` is now pending inclusion in the HSTS preload list!

Please make sure that `forensiq.pt` **continues** to satisfy all preload requirements, or it will be removed. Please revisit this site over the next few weeks to check on the status of your domain.

Also consider scanning for TLS issues using SSL Labs.

Removal

Be aware that inclusion in the preload list cannot easily be undone. Domains can be removed, but it takes months for a change to reach users with a Chrome update and we cannot make guarantees about other browsers. Don't request inclusion unless you're sure that you can support HTTPS for **your entire site and all its subdomains** in the long term.

However, we will generally honor requests to be removed from Chrome's preload list if you find that you have a subdomain that you cannot serve over HTTPS for strong technical or cost reasons. To request removal, please visit the removal form.

TLD Preloading

Owners of gTLDs, ccTLDs, or any other public suffix domains are welcome to preload HSTS across all their registerable domains. This ensures robust security for

the whole TLD, and is much simpler than preloading each individual domain. Please contact us if you're interested, or would like to learn more.